

THE HUMAN FIREWALL AUDIT

Cybersecurity Project – Social Engineering Awareness & Defense

Prepared by: Pawan Tiwari

Roll No.: 2303630100114

Program: B.Tech CSE

Institute: Ambalika Institute of Management & Technology

Fictional Target: StreamZone Studios Pvt. Ltd.

Purpose: Educational and defensive cybersecurity simulation

1. Project Overview

The Human Firewall Audit is an ethical cybersecurity simulation that demonstrates how social engineering can exploit human behavior, publicly available information, and weak verification practices. The project uses a fictional organization and does not target real people, companies, credentials, or systems.

The project combines OSINT-style reconnaissance, a multi-vector social-engineering scenario, awareness material, behavioral red flags, and technical/organizational defenses. A working Streamlit application demonstrates phishing analysis, password security, login-attempt monitoring, awareness guidance, and activity logging.

2. Objectives

- Understand how public information can expose an organization's attack surface.
- Demonstrate a safe, fictional multi-vector social-engineering scenario.
- Identify behavioral and technical warning signs.
- Create practical employee-awareness guidance.
- Design layered technical and organizational defenses.
- Demonstrate defensive concepts through a working application.

3. Target Organization Profile

Attribute	Details
Organization	StreamZone Studios Pvt. Ltd. (fictional)
Industry	Online entertainment / streaming
Approx. employees	~85
Location	Mumbai
Sensitive information	Sponsorship contracts, upcoming content, unreleased media
Primary exposure	Public social media, job postings, workflow/technology oversharing

4. Reconnaissance / OSINT Findings

- Public social-media content may reveal behind-the-scenes screens and work activity.
- Job listings expose tools and workflows such as Canva, Google Ads, and Slack.
- Some editors were described as using personal Google Drive spaces, creating a personal/company boundary risk.
- Marketing-related posts can expose travel or availability details.
- References to internal Slack/workflow practices in public content can help an attacker build believable pretexts.

Resulting attack surface: public technology/workflow exposure, oversharing, and weak personal/company boundaries.

5. Multi-Vector Social Engineering Scenario

Objective: In the fictional simulation, an attacker attempts to obtain access to unreleased episodes and sponsor-related information by combining two social-engineering vectors.

Vector 1 – Phishing: A fake talent-scout style message is designed to create urgency and direct the recipient toward a simulated login/upload page. The project does not collect real credentials.

Vector 2 – Fake Collaboration Account: A fictional influencer-style account contacts the PR function to reinforce the credibility of the opportunity and encourage trust through a second channel.

Why the combination matters: One channel creates the initial opportunity while another channel appears to confirm it. This demonstrates why independent verification is important.

6. Awareness Material

Poster theme: “Don’t Let Fame Fool You!”

Core awareness message: attractive opportunities, brand collaborations, or urgent partnership requests should be independently verified before opening links, sharing files, or providing account information.

Employees should verify the sender through an established company contact method, inspect domains and redirects, avoid pressure-based decisions, and report suspicious requests.

7. Red-Flag Checklist

- Unexpected partnership or collaboration request.
- Pressure to act immediately or maintain secrecy.
- Verification being requested through an unrelated DM or social account.
- Sender/domain mismatch.
- Unexpected redirects or login pages.
- Requests for passwords, authentication codes, or sensitive files.
- Unusual request for unreleased content or sponsor information.

8. Defense Strategy

Layer	Recommended defense
People	PR and employee social-engineering awareness; verification drills; reporting culture.
Identity & access	Zero-Trust access control; least privilege; controlled OAuth/application permissions.
Email	DMARC and related email-authentication controls; suspicious-link filtering.
Content	Digital watermarking for sensitive/unreleased media.
Detection	Phish-alert/reporting mechanism; activity monitoring; periodic simulations.
Response	Documented escalation process and rapid account/session review after a suspected incident.

9. Working Application

The project includes a Streamlit-based defensive demonstration application. It is intended for classroom evaluation and uses safe sample inputs rather than real credential collection or real-world phishing.

Module	Purpose
Dashboard	Project overview, threat model, and security posture.
Phishing Analysis	Heuristic inspection of suspicious keywords and URLs in a sample email.
Password Security	Checks password characteristics such as length, case, digits, and special characters.
Login Security	Demonstrates limited login attempts and account lockout behavior.
Awareness Center	Shows social-engineering red flags and recommended controls.
Activity Log	Displays defensive actions/events generated during the demo.

10. Defensive Demonstrations

Phishing detector: uses simple heuristics to flag suspicious keywords and URLs in a sample message. It is an educational detector, not a replacement for enterprise email security.

Password checker: evaluates basic password characteristics and provides a strength indication without storing a password.

Login monitor: demonstrates a three-attempt limit followed by lockout, illustrating the value of rate limiting and account protection.

Awareness center: connects human warning signs to practical defensive controls.

11. Reference Scenarios

The source project document references public examples involving phishing and social-media/influencer scams to illustrate why human verification and awareness are important. These examples are used only as educational context; this project itself uses a fictional target and does not reproduce or conduct a real attack.

12. Ethical Statement

This project is fictional, educational, and defensive. No real organization is targeted, no real person is impersonated, and no real credentials are collected. The simulated workflow is intended to teach recognition, verification, reporting, and layered defense.

13. Conclusion & Future Scope

The Human Firewall Audit demonstrates that cybersecurity is not only a technical problem. Public information, human trust, urgency, and cross-channel communication can influence how convincing a social-engineering attempt appears. A strong defense therefore combines employee awareness, independent verification, identity and access controls, email security, monitoring, and incident response.

Future scope includes adding a database-backed event log, role-based access, richer phishing classification, configurable awareness simulations, dashboard analytics, and integration with controlled security-training environments.